

Riesgo asociado	Tipo de prueba	Técnica o herramienta	Caso de prueba	Responsable	Evidencia
Acceso no autorizado	Estática	Revisión de código + SAST (Bandit)	Verificar que todas las rutas y endpoints protegidos implementan verificación de roles y permisos (RBAC).	Kathleen González	Captura de pantalla del código con decoradores/permisos implementados; reporte de Bandit sin vulnerabilidades críticas.
Acceso no autorizado	Dinámica	Prueba funcional de seguridad	Intentar acceder a módulos restringidos (ej. panel de administración, consulta de historiales) sin tener un rol válido o sin estar autenticado.	Freddy Herrera	Captura de pantalla mostrando mensaje de "Acceso denegado" o redirección a login; registro del intento en logs.
Fallos de autenticación o autorización	Estática	Revisión de código + SAST (Bandit)	Verificar que las contraseñas se almacenan utilizando algoritmos de hashing seguros (ej. bcrypt, Argon2).	Kathleen González	Captura de pantalla del código de hashing; reporte de Bandit sin almacenamiento de contraseñas en texto plano.
Fallos de autenticación o autorización	Dinámica	Prueba funcional de seguridad	Verificar que el sistema bloquea el acceso después de múltiples intentos fallidos de autenticación (ej. 5 intentos en 5 minutos).	Cesia Juárez	Captura de pantalla mostrando el bloqueo de la cuenta; registro del evento en logs.
Fallos de autenticación o autorización	Dinámica	Prueba de autorización	Intentar acceder a datos de un paciente diferente al que el usuario tiene permitido (prueba de autorización horizontal).	Cesia Juárez	Captura de pantalla mostrando mensaje de "No autorizado para ver este registro"; log del intento.
Validación deficiente de entradas	Estática	Revisión de código + Linter (Pylint/Flake8)	Verificar que todos los formularios y endpoints de API implementan validación en servidor y sanitización de entradas.	Kathleen González	Captura de pantalla del código revisado con validaciones implementadas; reporte de linter sin errores críticos.
Inyección de código	Dinámica	Prueba funcional de seguridad + OWASP ZAP	Intentar inyectar comandos SQL (' OR '1'='1) y scripts en formularios de búsqueda y consulta de historiales.	Freddy Herrera	Captura de pantalla mostrando que los inputs maliciosos son rechazados; reporte de OWASP ZAP sin vulnerabilidades críticas.
Inyección de	Estática	Revisión de código +	Verificar que todas las consultas a la	Kathleen González	Captura de pantalla del código con

código		SAST (Bandit)	base de datos utilizan consultas parametrizadas o ORM, evitando concatenación de strings.		consultas parametrizadas; reporte de Bandit sin vulnerabilidades de inyección.
Exposición de datos sensibles	Estática	Revisión de código + SAST (Bandit)	Verificar que los identificadores de pacientes y usuarios son seudonimizados (hashed con sal) antes de ser almacenados o transmitidos.	Freddy Herrera	Captura de pantalla del código de transformación (hash con sal); reporte de Bandit sin datos sensibles en texto plano.
Exposición de datos sensibles	Dinámica	Prueba funcional de seguridad	Verificar que los mensajes de error no exponen información sensible (ej. estructura de BD, rutas de archivos, versiones de software).	Cesia Juárez	Captura de pantalla mostrando mensajes de error genéricos; verificación de que no se exponen detalles internos.
Fuga de datos en tránsito	Dinámica	Prueba funcional de seguridad + OWASP ZAP	Verificar que todas las comunicaciones entre módulos utilizan TLS 1.3 y que los datos en reposo están cifrados con AES-256.	Freddy Herrera	Captura de pantalla de certificado SSL/TLS; reporte de OWASP ZAP sin vulnerabilidades de cifrado.
Gestión insegura de sesiones	Estática	Revisión de código + Linter	Verificar que las sesiones tienen tiempo de expiración configurable y que se regenera el ID de sesión después del login.	Kathleen González	Captura de pantalla del código de gestión de sesiones; configuración de timeout.
Gestión insegura de sesiones	Dinámica	Prueba funcional de seguridad	Intentar utilizar una sesión después del tiempo de expiración; verificar que se solicita autenticación nuevamente.	Kathleen González	Captura de pantalla mostrando redirección a login después de expirar la sesión.
Falta de procedimiento de respuesta a incidentes	Dinámica	Prueba funcional de seguridad + Logging	Simular un intento de acceso no autorizado y verificar que: 1) se registra en logs, 2) se genera una alerta, 3) el evento es visible en el panel de monitoreo.	Kathleen González Cesia Juárez	Captura de pantalla del log con el evento registrado; captura de la alerta generada; captura del dashboard de monitoreo.
Uso inseguro de dependencias	Estática	Análisis de dependencias (Safety, Snyk, Dependabot)	Revisar todas las librerías y paquetes utilizados en el proyecto, identificando versiones obsoletas o con vulnerabilidades conocidas.	Freddy Herrera	Reporte de análisis de dependencias; lista de vulnerabilidades encontradas y acciones correctivas.

Errores de configuración	Estática	Revisión de configuración	Verificar que las credenciales, claves API y tokens no están almacenados en el código fuente, sino en variables de entorno (archivo .env).	Cesia Juárez	Captura de pantalla del archivo .env (con valores ofuscados); verificación de que no hay credenciales en el código.
Errores de configuración	Dinámica	Prueba de configuración	Verificar que los encabezados de seguridad HTTP (HSTS, CSP, X-Frame-Options) están configurados correctamente.	Freddy Herrera	Captura de pantalla de los encabezados HTTP; reporte de herramientas como SecurityHeaders.com.
Registros inconsistentes	Estática	Revisión de código	Verificar que todos los módulos registran los eventos de acceso en un formato estandarizado y consistente.	Kathleen González	Captura de pantalla del código de logging; verificación de formato unificado.
Registros inconsistentes	Dinámica	Prueba funcional de seguridad	Generar eventos de acceso desde diferentes módulos y verificar que todos se registran en el sistema centralizado de logs con el mismo formato.	Freddy Herrera Kathleen González Cesia Juárez	Captura de pantalla del sistema centralizado de logs mostrando eventos de diferentes módulos con formato consistente.